



Ecole Reconnue par l'Etat



ECOLE MAROCAINE DES SCIENCES DE L'INGENIEUR

Filière : 3IIR | Année Universitaire 2025/2026

Module : Programmation Python Framework.

CAHIER DES CHARGES

Projet de Fin d'Année (PFA)

Plateforme E-commerce Sécurisée avec IDS Basique

Titre du Projet	Plateforme E-commerce Sécurisée avec IDS Basique.
Filière	3IIR — Ingénierie Informatique et Réseaux
Modules	Programmation Python Framework
Binôme	
Durée du Projet	2 mois — du 19/03/2026 au 19/05/2026
Encadrant	Mme. Asmaa kassid.

Table des Matières

1. Introduction
2. Présentation Générale du Système
3. MVP — Produit Minimum Viable
4. Périmètre du Projet
5. Spécifications Fonctionnelles
 - 5.1 Gestion des Comptes Utilisateurs
 - 5.2 Gestion des Produits
 - 5.3 Gestion des Commandes
 - 5.4 Module Administration
 - 5.5 Module IDS Python
6. Spécifications Techniques
7. Diagrammes UML
 - 7.1 Diagramme de Cas d'Utilisation (Use Case)
 - 7.2 Diagramme de Classes
 - 7.3 Diagramme d'Activité — Passer une Commande
8. Gestion du Projet — Planning Agile Scrum / Jira
9. Livrables Attendus
10. Conclusion

1. Introduction

1.1 Contexte du Projet

De nombreux vendeurs locaux manquent de visibilité numérique pour écouler leurs produits à grande échelle. Les clients (boutiques, hôtels, particuliers) ne disposent pas d'une plateforme dédiée et sécurisée pour s'approvisionner facilement. Ce projet répond à ce besoin en développant une plateforme e-commerce sécurisée avec gestion des stocks, des commandes, de la facturation PDF et un module IDS en Python.

1.2 Description & Objectifs de la Plateforme

Objectif General

La plateforme permettra aux vendeurs de créer leurs boutiques virtuelles et aux clients de parcourir le catalogue, passer des commandes et télécharger leurs factures PDF. Un tableau de bord administrateur supervise la plateforme et affiche en temps réel les alertes du module IDS Python. Les trois objectifs principaux sont :

- Fournir un système complet de vente en ligne : catalogue, panier, commandes, stocks et facturation PDF.
- Garantir la sécurité de l'application contre XSS, SQL Injection et CSRF, avec un module IDS Python de détection d'intrusion en temps réel.
- Proposer une interface intuitive et des recommandations de produits similaires pour améliorer l'expérience utilisateur.
-

2.2 Problématique

- Comment concevoir une plateforme e-commerce B2B fonctionnelle et securisee qui :
- Permette aux artisans de gérer leurs produits, stocks et commandes de maniere centralisée ?
- Protège les données des utilisateurs et les transactions contre les attaques web courantes ?
- Detecte et alerte en temps reel les tentatives d'intrusion ou de comportements anormaux ?

2. Présentation Générale du Système

2.2 Utilisateurs finaux du Système

Utilisateur	Description	Actions Principales
Administrateur	Supervise et gère la plateforme	Gestion user, produits, catégories, stats, alertes IDS
Vendeur	Vendeur de produits.	CRUD produits, gestion stock, suivi commandes reçues
Client	Acheteur professionnel ou particulier	Navigation catalogue, panier, commandes, factures PDF

3. MVP — Produit Minimum Viable

Compte tenu de la durée du projet (2 mois) et du niveau de départ en Python, le MVP définit les fonctionnalités qui seront obligatoirement livrées lors de la soutenance.

Priorité	Fonctionnalité
Critique	Authentification : inscription, connexion, JWT, gestion rôles.
	CRUD Produits par le client / vendeur (nom, description, prix, stock, images)
	Catalogue produits public avec filtres (catégorie, prix)
	Panier d'achat + passation de commande
	Module IDS Python : détection les cyber-attaques SQL, XSS, Brute Force.
Important	Alertes IDS visibles dans le Dashboard Admin (polling 30s)
	Génération des factures en format PDF et Excel.
	Gestion des stocks (déduction automatique à chaque commande)

- **Le module IDS est un script Python indépendant (ids.py) qui lit les logs Django, détecte les patterns suspects avec des expressions régulières simples, et écrit les alertes dans la table SecurityAlert de la base de données via l'ORM Django.**

4. Périmètre du Projet

4.1 Dans le Périmètre (In Scope)

- Application web responsive - React.js (frontend) + Django REST Framework (backend)
- Base de données MySQL via Laragon
- Module IDS Python indépendant (script ids.py) communiquant via la BDD
- Dashboard admin avec affichage des alertes sécurité en temps réel (polling 30s)
- Génération automatique de factures PDF (Reporta)
- Authentification JWT (Access token + refresh token)
- Moteur de recommandation simple (filtrage par catégorie)
- Protection web: XSS, CSRF, SQL Injection

4.2 Hors Perimeter (Out of Scope)

- Passerelle de paiement bancaire réelle (paiement simule uniquement)
- Logistique et suivi de livraison réelle
- IDS base sur le Machine Learning ou Deep Learning
- Déploiement sur serveur cloud public (environnement local Laragon suffit pour le PFA)

5. Spécifications Fonctionnelles

5.1 Gestion des Comptes Utilisateurs

Fonctionnalite	Description
Inscription	Formulaire avec validation : email unique, mot de passe fort, choix du rôle (Vendeur ou Client).
Connexion / Déconnexion	Authentification JWT — Access token + refresh token.
Gestion du profil	Modification des informations personnelles
Réinitialisation MDP	Lien de réinitialisation du mot de passe par email
Contrôle d'accès	Chaque rôle (Admin, vendeur, Client) accède uniquement à son espace dédié

5.2 Gestion des Produits

Fonctionnalite	Description
Ajouter un produit	Formulaire complet : nom, description, prix, catégorie, stock, images
Modifier un produit	Mise à jour de tous les champs et remplacement des images
Supprimer un produit	Suppression (archivage logique pour préserver l'historique des commandes)
Gestion du stock	Mise à jour manuelle + déduction automatique à chaque commande validée
Dashboard Vendeur	Vue synthétique : ses produits, alertes stock bas, commandes reçues

5.3 Gestion des Commandes (Client)

Fonctionnalite	Description
Catalogue & Filtres	Navigation par catégorie, prix, vendeur, disponibilité en stock
Panier d'achat	Ajout, suppression, modification des quantités
Passation de commande	Validation du panier, vérification des stocks, création de la commande
Suivi des commandes	Statuts : En attente, Confirmée, En préparation, Expédiée, Livrée
Facture PDF et Excel	Téléchargement de la facture générée par ReportLab après validation

5.4 Module Administration

Fonctionnalité	Description
Gestion utilisateurs	Activer, désactiver, modifier le rôle des comptes
Gestion des produits	Supprimer les annonces frauduleuses ou non conformes
Gestion catégories	CRUD sur les catégories de produits Vendeur aux
Statistiques	Tableau de bord : CA total, produits les plus vendus, nombre de commandes
Alertes IDS	Panneau dédié affichant les alertes du module Python (type, IP, payload, sévérité)

5.5 Module IDS Python (Intrusion Détection System)

Le module IDS est un script Python indépendant (ids.py) qui s'exécute en parallèle de l'application Django sans impacter ses performances.

Fonctionnement General

1. Le script Python lit périodiquement les logs Django (fichier django.log).
2. Pour chaque entrée de log, il applique des expressions régulières (regex) simples.
3. Si un pattern suspect est détecté, un enregistrement est créé dans la table SecurityAlert via l'ORM Django.
4. Le Dashboard admin appelle GET /api/Security/alerts/ toutes les 30 secondes (polling simple).
5. Les nouvelles alertes s'affichent dans le panneau sécurité avec couleur selon la sévérité.

Types d'Attaques Détectées

Attaque	Méthode de Détection (Python regex)
SQL Injection	Patterns : UNION SELECT, DROP TABLE, --, ; SELECT, xp_cmdshell
XSS	Patterns : <script, javascript : onerror=, alert (, <iframe
Brute Force Login	Comptage des erreurs HTTP 401/403 par IP sur une fenêtre de 10 minutes
Path Traversal	Patterns : ../, /etc/passwd, /proc/self

Structure d'une Alerte (table SecurityAlert)

Champ	Description
Id	Identifiant unique de l'alerte (auto-increment)
Timestamp	Date et heure de détection
Type_attaque	Catégorie : SQLi, XSS, BruteForce, PathTraversal
Ip_source	Adresse IP de l'attaquant présume
Url_ciblee	Endpoint HTTP vise par la requête suspecte
Payload_suspect	Extrait de la requête suspecte (censure si trop long)
Sévérité	Bas, Moyen, Eleve, Critique
Statut	Nouveau, Vu, Résolu

6. Spécifications Techniques

6.1 Stack Technologique

Couche	Technologies & Outils
Frontend	React.js, Axios, React Router, Bootstrap
Backend	Django 4 (Python 3.14), Django REST Framework (DRF), JWT via Django rest Framework-simple jwt
Base de données	MySQL via Laragon, ORM Django exclusivement (zero SQL brut)
Module IDS	Python 3.14, librairies : re (regex), time, os, Django (ORM via setup Django)
Générateur PDF et Excel	ReportLab (Python) — génération des factures PDF et Excel cote backend Django
Authentification	JWT — Access token (expiration courte) + refresh token (7 jours)
Communication IDS	Ecriture directe dans la table SecurityAlert via ORM Django
Environnement Dev	VS Code et Antigravity, Laragon (MySQL), Git/GitHub

6.2 Contraintes Techniques

- L'application doit être responsive et fonctionner sur Chrome, Firefox et Edge.
- L'API REST doit être testée avec Postman et documentée avant chaque sprint review.
- Le code doit être versionné sur GitHub avec des messages de commit explicites.
- Les mots de passe et tokens ne doivent jamais être stockés en clair.
- Le module IDS (ids.py) doit s'exécuter en arrière-plan sans impacter l'application principale.
- Laragon sera utilisé pour héberger MySQL en local.

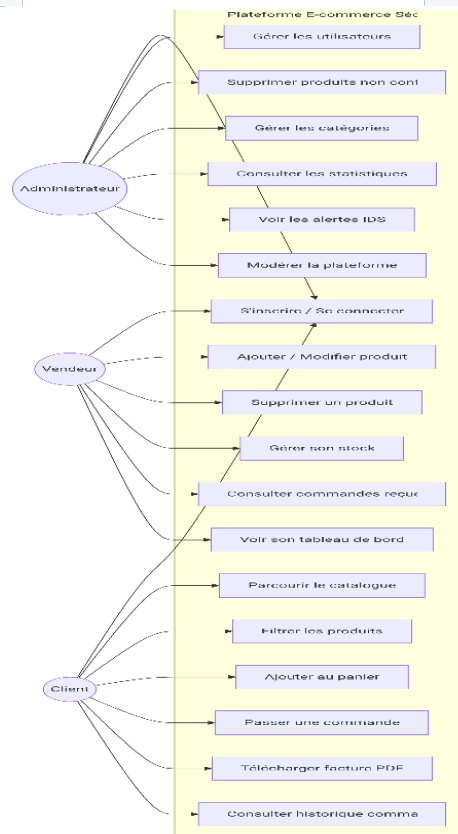
7. Diagrammes UML

Cette section présente les trois diagrammes UML principaux du projet. Les versions finales et détaillées seront réalisées avec draw.io ou startUML et intégrées dans le rapport technique.

7.1 Diagramme de Cas d'Utilisation (Use Case)

Le diagramme de cas d'utilisation identifie les interactions entre les 3 acteurs du système et les fonctionnalités de la plateforme.

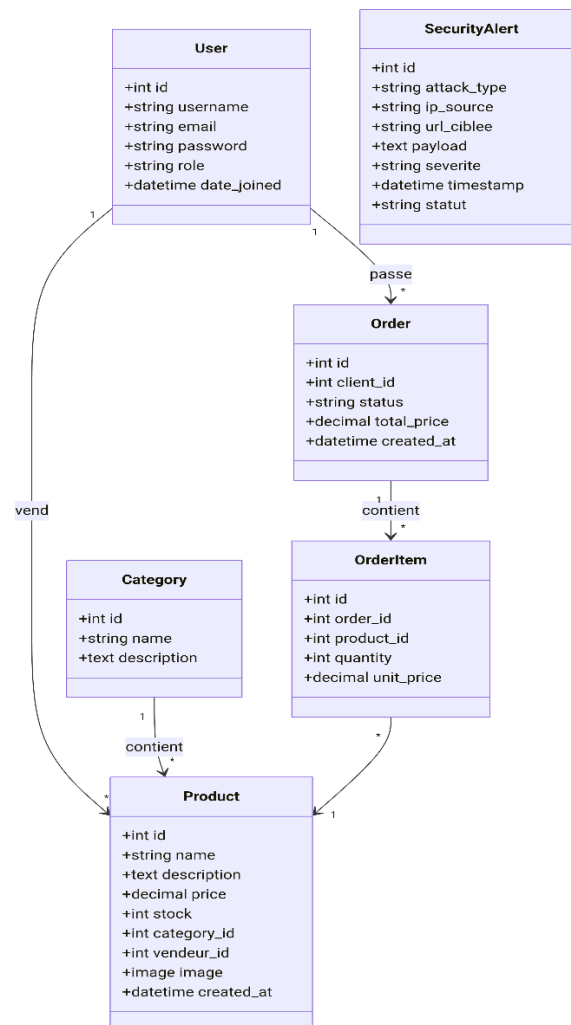
Administrateur	Vendeur	Client
- Gérer les utilisateurs - Supprimer produits non conformes - Gérer les catégories - Consulter les statistiques - Voir les alertes IDS - Moderer la plateforme	- S'inscrire / Se connecter - Ajouter / Modifier produit - Supprimer un produit - Gérer son stock - Consulter commandes reçues - Voir son tableau de bord	- S'inscrire / Se connecter - Parcourir le catalogue - Filtrer les produits - Ajouter au panier - Passer une commande - Télécharger facture PDF - Consulter historique commandes



7.2 Diagramme de Classes

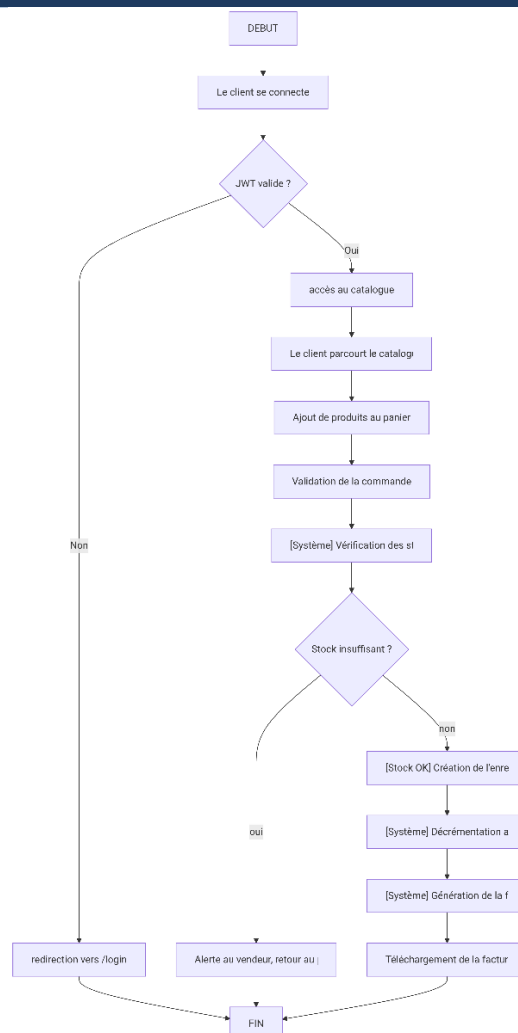
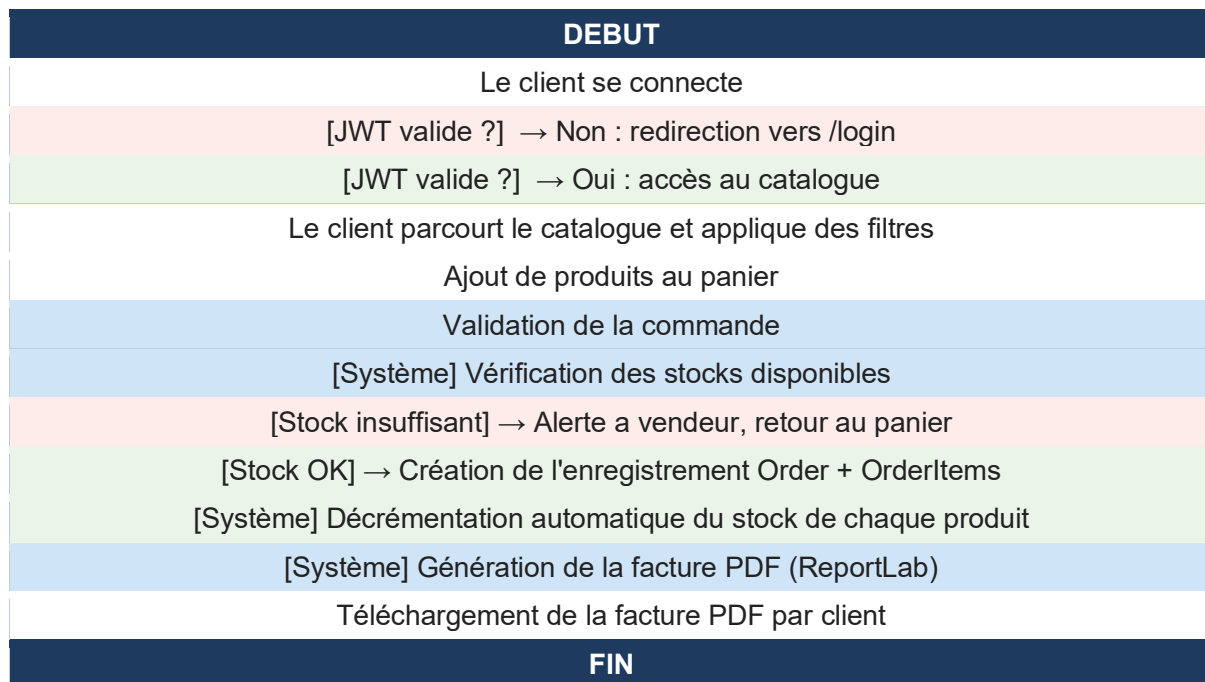
Le diagramme de classes présente les principales entités de la base de données et leurs relations. Ces classes correspondent directement aux modèles Django (models.py).

Classe (Modèle Django)	Attributs Principaux	Relations
User	Id, username, email, password (bcrypt), role (admin / vendeur / client), date_joined	1 User → N Products 1 User → N Orders
Product	Id, Name, description, Price, stock, category_id, Vendeur_id, image, created_at	N Products → 1 Category N Products → 1 User (vendeur)
Category	Id, Name, description	1 Category → N Products
Order	Id, client_id, status, total_price, created_at	1 Order → N OrderItems 1 Order → 1 User (client)
OrderItem	Id, order_id, product_id, quantity, unit_price	N OrderItems → 1 Order N OrderItems → 1 Product
SecurityAlert (IDS)	Id, attack_type, ip_source, url_ciblee, payload, severite, timestamp, statut	Table indépendante, écrite par le script ids.py



7.3 Diagramme d'Activité — Passer une Commande

Ce diagramme décrit le flux complet de passation d'une commande, de la connexion jusqu'au téléchargement de la facture PDF.



8. Gestion du Projet — Planning Agile Scrum / Jira

- Le projet est organisé selon la méthodologie Agile Scrum en 5 Sprints.
- Le suivi des tâches est réalisé sur Jira.
- La durée totale du projet est de 2 mois : du 19/03/2026 au 19/05/2026.

Sprint	Objectif	Tâches Principales	Période
Sprint 1 : Conception & Setup	Poser les bases du projet	- Diagrammes UML (Use Case, Classes, Activité, Séquence.) - Création du dépôt GitHub - Setup Django + React + MySQL (Laragon) - Configuration JWT + modèles BDD - Initialisation du projet React.	1 semaine 19/03/2026 au 25/03/2026
Sprint 2 : Authentification & Sécurité	Auth complète + protections web	- API Register & Login (bcrypt + JWT) - Middlewares CSRF + protection XSS - Formulaires React (inscription / connexion) - Gestion des rôles RBAC - Structure de base du module IDS (ids.py)	2 semaines 26/03/2026 au 8/04/2026
Sprint 3 Catalogue & Vendeur	Espace Vendeur + catalogue produits	- API CRUD produits - Page catalogue React avec filtres - Dashboard Vendeur (liste produits, stock) - IDS : détection SQLi + XSS via regex - Alertes IDS dans le Dashboard admin	2 semaines 9/04/2026 au 22/04/2026
Sprint 4 E-commerce	Flux de commande complet	- Logique panier (ajout, suppression, quantités) - API validation commande + déduction stocks - Moteur de recommandation - Génération facture PDF (ReportLab) - IDS : détection Brute Force + Path Traversal	2 semaines 23/04/2026 au 6/05/2026
Sprint 5 Finalisation & Rapport	Finitions + documentation + soutenance	- Tests & correction des bugs - Rédaction rapport (Etat de l'Art) - Préparation slides soutenance	12 jours 7/05/2026 au 18/05/2026

9. Livrables Attendus

9.1 Livrables Techniques

- Code source versionné sur GitHub (repository privé, accès à l'encadrants)
- Application web fonctionnelle tournant en local avec Laragon
- Script Python IDS indépendant (ids.py) avec README d'utilisation
- Migrations Django pour la création de la base de données MySQL

9.2 Livrables Documentaires

- Ce Cahier des Charges.
- Rapport technique final : Introduction, Etat de l'Art, Conception (UML), Réalisation, Sécurité, Conclusion.
- Présentation PowerPoint pour la soutenance avec démo live.

10. Conclusion

Ce projet constitue une opportunité concrète de mettre en pratique les compétences acquises en développement web full-stack, en sécurité des applications et en gestion de projet Agile. La plateforme e-commerce, combinée au module IDS Python, répond à un besoin réel de digitalisation tout en démontrant l'importance de la cybersécurité dans les applications modernes. Les choix technologiques (Django, React, MySQL, ReportLab) sont adaptés au niveau et au délai impartis, garantissant un livrable fonctionnel, documenté et soutenu par une démarche académique rigoureuse conforme aux exigences du PFA.